

Identity and access management fundamental concepts

Summarize this article for me

This article explains the fundamental concepts of identity and access management (IAM) to help you secure resources effectively.

What is identity and access management

Identity and access management ensures that the right people, machines, and software components access the right resources at the right time. First, the person, machine, or software component proves they're who or what they claim to be. Then, the person, machine, or software component is either granted or denied access to certain resources.

What IAM does

IAM systems typically provide the following core functionality:

- **Identity management:** The process of creating, storing, and managing identity information. Identity providers (IdP) are software solutions that are used to track and manage user identities, as well as the permissions and access levels associated with those identities.
- **Identity federation:** Allow users who already have passwords elsewhere (for example, in your enterprise network or with an internet or social identity provider) to access your system.
- **Provisioning and deprovisioning of users:** Create and manage user accounts, including specifying which users can access which resources and assigning permissions and access levels.
- **Authentication of users:** Confirm that a user, machine, or software component is who or what they claim to be.
- **Authorization of users:** Ensures a user is granted the exact level and type of access to a tool they're entitled to.
- **Access control:** The process of determining who or what has access to which resources. This process includes defining user roles and permissions, as well as setting up authentication and authorization mechanisms. Access controls regulate access to systems and data.
- **Reports and monitoring:** Generate reports about platform actions (such as sign-in time, systems accessed, and type of authentication) to ensure compliance and assess security risks.

Identity

A digital identity is a collection of unique identifiers or attributes that represent a person, software component, machine, asset, or resource in a system. An identifier can be:

- An email address
- Sign-in credentials (username/password)
- A bank account number
- A government issued ID
- A MAC address or IP address

Identities are used to authenticate and authorize access to resources, enable communication, facilitate transactions, and serve other purposes.

Identities are categorized into three types:

- **Human identities** represent people, including employees (internal and frontline workers) and external users (customers, consultants, vendors, and partners).
- **Workload identities** represent software workloads such as an application, service, script, or container.
- **Device identities** represent devices, including desktop computers, mobile phones, IoT sensors, and IoT-managed devices. They're distinct from human identities.

Authentication

Authentication challenges a person, software component, or hardware device for credentials to verify their identity or prove they're who or what they claim to be. Authentication typically requires credentials such as a username and password, fingerprints, certificates, or one-time passcodes. Authentication is sometimes shortened to *AuthN*.

Multifactor authentication (MFA) is a security measure that requires users to provide more than one piece of evidence to verify their identity. Examples include:

- Something they know, such as a password.
- Something they have, like a badge.
- Something they are, like a biometric (fingerprint or face).

Single sign-on (SSO) lets users authenticate their identity once and then silently authenticate later when accessing various resources that rely on the same identity. After authentication, the IAM

system acts as the source of identity truth for other resources available to the user. It removes the need for signing on to multiple, separate target systems.

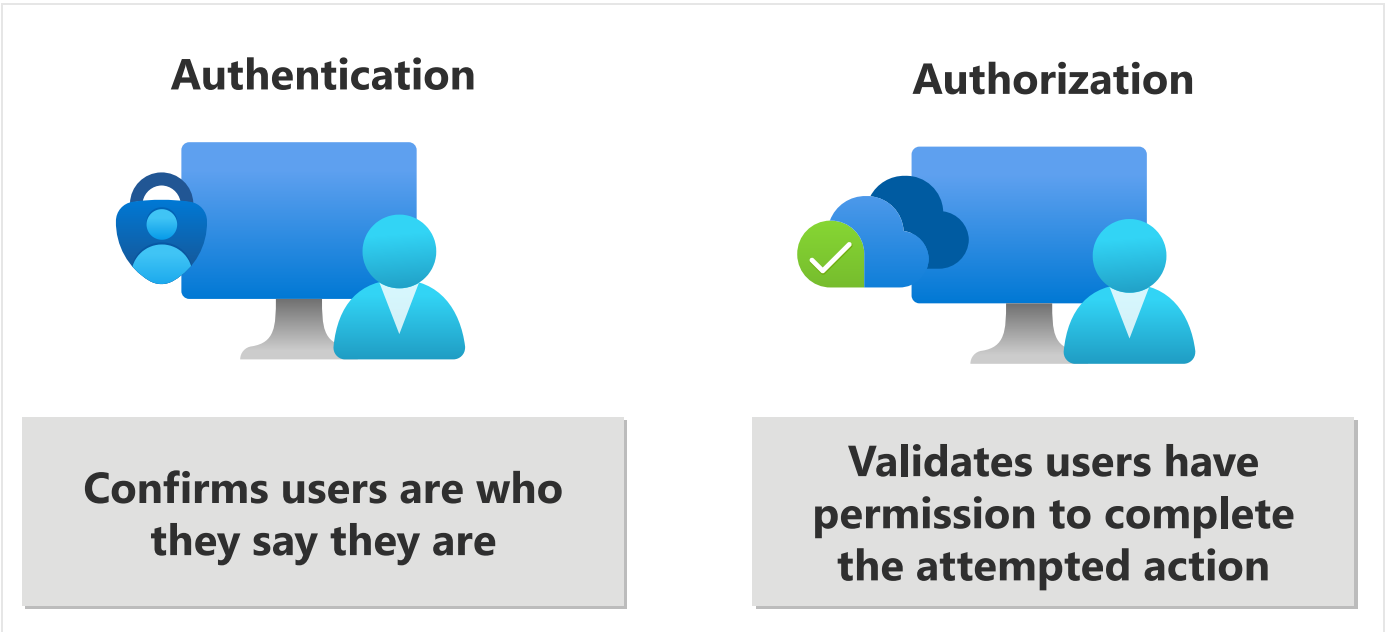
Authorization

Authorization validates that the user, machine, or software component is granted access to certain resources. Authorization is sometimes shortened to *AuthZ*.

Authentication vs. authorization

The terms authentication and authorization are sometimes used interchangeably because they often seem like a single experience to users. They're actually two separate processes:

- Authentication proves the identity of a user, machine, or software component.
- Authorization grants or denies the user, machine, or software component access to certain resources.



Here's a quick overview of authentication and authorization:

 Expand table

Authentication	Authorization
Can be thought of as a gatekeeper, allowing access only to those entities who provide valid credentials.	Can be thought of as a guard, ensuring that only those entities with the proper clearance can enter certain areas.

Authentication	Authorization
Verifies whether a user, machine, or software is who or what they claim to be.	Determines if the user, machine, or software is allowed to access a particular resource.
Challenges the user, machine, or software for verifiable credentials (for example, passwords, biometric identifiers, or certificates).	Determines what level of access a user, machine, or software has.
Done before authorization.	Done after successful authentication.
Information is transferred in an ID token.	Information is transferred in an access token.
Often uses the OpenID Connect (OIDC) (which is built on the OAuth 2.0 protocol) or SAML protocols.	Often uses the OAuth 2.0 protocol.

For more detailed information, read [Authentication vs. authorization](#).

Example

Suppose you want to spend the night in a hotel. You can think of authentication and authorization as the security system for the hotel building. Users are people who want to stay at the hotel, resources are the rooms or areas that people want to use. Hotel staff is another type of user.

If you're staying at the hotel, you first go to reception to start the "authentication process." You show an identification card and credit card and the receptionist matches your ID against the online reservation. After the receptionist verifies who you are, the receptionist grants you permission to access the room you're assigned to. You're given a keycard and can go now to your room.



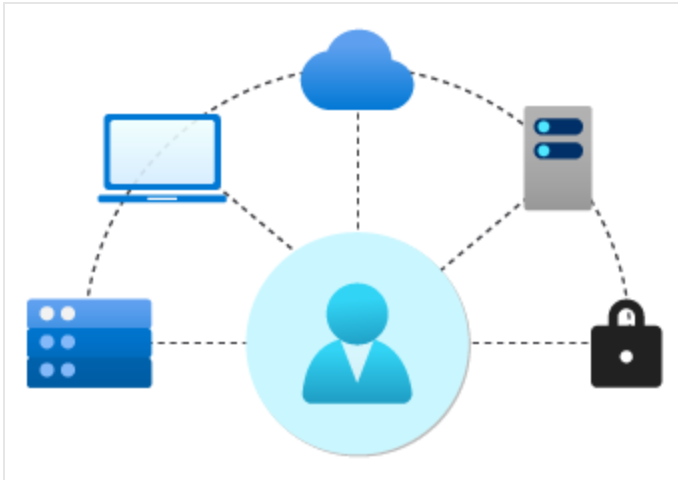
The doors to the hotel rooms and other areas have keycard sensors. Swiping the keycard in front of a sensor is the "authorization process." The keycard only lets you open the doors to rooms you're permitted to access, such as your hotel room and the hotel exercise room. If you swipe your keycard to enter any other hotel guest room, your access is denied.

Individual [permissions](#), such as accessing the exercise room and a specific guest room, are collected into [roles](#), which can be granted to individual users. When you're staying at the hotel, you're granted the Hotel Patron role. Hotel room service staff would be granted the Hotel Room Service role. This role permits access to all hotel guest rooms (but only between 11am and 4pm), the laundry room, and the supply closets on each floor.



Identity provider

An identity provider creates, maintains, and manages identity information. It offers authentication, authorization, and auditing services.



With modern authentication, all services, including authentication services, are supplied by a central identity provider. The identity provider centrally stores and manages information used to authenticate the user with the server.

A central identity provider lets organizations establish authentication and authorization policies, monitor user behavior, identify suspicious activities, and reduce malicious attacks.

[Microsoft Entra](#) is an example of a cloud-based identity provider. Other examples include X, Google, Amazon, LinkedIn, and GitHub.

Next steps

- Learn about [single sign-on \(SSO\)](#).
- Learn about [multifactor authentication \(MFA\)](#).

Last updated on 08/20/2025